



- **Theoretical implementation**

Threat Hunting Methodologies

- Threat hunting is a proactive cybersecurity activity where security analysts actively search for hidden threats inside an organization's environment before automated security tools generate alerts. Traditional security monitoring is mostly reactive because analysts respond only after alerts are triggered. Threat hunting, however, focuses on discovering malicious activity that may bypass SIEM rules, antivirus solutions, or endpoint detection systems.
- Modern attackers often use stealthy techniques to remain undetected for long periods. Advanced Persistent Threats (APTs), insider threats, and credential abuse attacks may generate very few alerts. Threat hunting helps SOC analysts identify these hidden threats by analyzing logs, behaviors, network traffic, and attacker tactics.

1. Proactive Threat Hunting

- Proactive threat hunting involves actively searching for suspicious behavior without waiting for automated alerts. Analysts assume attackers may already exist inside the environment and investigate indicators that suggest compromise.
- Unlike reactive incident response, where analysts respond after detection, proactive hunting focuses on identifying threats early.

- Hypothesis-Driven Hunting

- Threat hunting commonly follows a hypothesis-driven approach. Analysts create hypotheses based on attacker TTPs, threat intelligence, or suspicious behavior patterns
- E.g. Attackers may be abusing valid accounts for persistence. Threat hunters then investigate logs and telemetry to confirm or reject this hypothesis.
- Some example are follows :
 1. **Valid Accounts Misuse** (T1078 – Valid Accounts) :
 - Attackers use stolen credentials to appear legitimate.
 - Threat hunters search for unusual login locations, abnormal login times , VPN anomalies, unauthorized administrative activity.
 2. **PowerShell Hunting** (T1059.001 – PowerShell) :
 - Threat hunters search endpoint logs for powershell.exe - EncodedCommand.
 - This may indicate malware execution, remote command execution, attacker persistence.



2. Hunting Frameworks

- Threat hunting frameworks provide structured methodologies for conducting investigations systematically and efficiently.
- Frameworks help analysts to standardize hunting processes, improve investigation quality, organize hunting activities, document findings properly.
- SqRR Framework
 - SqRR stands for Search Query Retrive Respond
 - This framework provides a systematic approach for threat hunting investigations.
 - Threat hunters identify suspicious indicators or hypotheses. Eg. Search for unusual RDP logins.
 - Threat hunters create queries to search SIEM or EDR data. Eg. Search for Event ID 4624 outside business hours.
 - Relevant logs and evidence are collected from SIEM platform, endpoint, network traffic, EDR solutions, authentication systems.
 - Threat hunters analyze retrieved data for suspicious patterns.
 - If malicious activity is confirmed incident response begins, system are isolated. IOCs are blocked, tickets are escalated.
- TaHiTI Framework
 - TaHiTI Framework stands for Targeted Hunting integrating Threat Intelligence.
 - This framework combines threat hunting with threat intelligence.
 - Threat hunters use threat feeds, attacker TTPs, IOC intelligence, known adversary behaviors to guide investigations.

3. Data Sources for Hunting

- Threat hunting relies heavily on high-quality data sources.
- The more visibility hunters have, the more effective investigations become.
- Endpoint Detection and Response (EDR) Logs
 - EDR platforms provide process execution data, command-line activity, registry changes, file modifications, malware detections.
 - Threat hunters use EDR data to identify suspicious endpoint behavior.
 - Eg. Threat hunters search for cmd.exe spawning powershell.exe.



- Network Traffic
 - Network logs reveals outbound connections, lateral movement, data exfiltration, beaconing activity.
 - Threat hunters analyze firewall logs, proxy logs, DNS queries
- Threat Intelligence Feeds
 - Threat intelligence feeds provides malicious Ips, malware hashes, phishing domains, ransomware indicators .
 - Threat hunters compare organizational logs against known indicators.

Advanced SOAR Automation

- Advanced SOAR Automation is an important capability in modern Security Operations Centers (SOC). As organizations grow, security teams must handle thousands of alerts daily from SIEMs, firewalls, EDR tools, IDS/IPS systems, cloud platforms, and email gateways. Manually investigating and responding to every alert becomes difficult and time-consuming.
- Security Orchestration, Automation, and Response (SOAR) platforms help SOC teams automate repetitive tasks, integrate security tools, and accelerate incident response workflows. SOAR reduces analyst workload, improves response speed, minimizes human error, and allows analysts to focus on high-priority threats.

1. SOAR Components

- SOAR stands for Security, Orchestration, Automation, Response.
- Each component plays a different role in cybersecurity operations.
- Orchestration
 - Orchestration refers to integrating multiple security tools, platforms, and workflows into a centralized process.
 - Security environments often contain many disconnected tools such as SIEM platforms, firewalls, antivirus solutions, EDR systems, ticketing systems, threat intelligence feeds, email gateways
 - SOAR orchestration connects these tools together so they can share information automatically.
- Automation



- Automation refers to automatically performing repetitive security tasks without manual intervention.
- SOC analysts often perform repetitive actions such as checking IP reputation, enriching alerts, assigning tickets, blocking malicious domains, isolating endpoints. SOAR platforms automate these tasks.
- E.g Automated IP Reputation Check, Auto-Ticketing, Automated Alert Enrichment.
- Response
 - Response refers to automated or semi-automated actions taken to contain or mitigate threats.
 - SOAR platforms can automatically perform containment actions when threats are detected.
 - SOAR systems may isolate infected endpoints, disable compromised accounts, block malicious Ips, remove phishing emails, quarantine files, block malicious hashes, terminate suspicious processes

2. Playbook Development

- A playbook is a predefined automated workflow used to handle specific security incidents.
- Playbooks standardize response procedures and ensure consistent handling of incidents.
- Playbooks helps to reduce response time, automate repetitive actions, standardize incident handling, reduce analyst workload, improve SOC consistency.
- SOC teams commonly create playbooks for phishing emails, malware infections, brute-force attacks, suspicious logins, ransomware detection, data exfiltration, malicious IP detection
- Steps include in playbook development : eg phishing response playbook.

Step 1 – Alert Detection

- Email gateway detects suspicious email.

Step 2 – Automated Analysis

- SOAR: extracts URLs, analyzes attachments, checks sender reputation, queries threat intelligence feeds

Step 3 – Decision Point

- If malicious indicators exist it classify as phishing, escalate severity

Step 4 – Automated Response



- SOAR removes email from inboxes, blocks malicious domains, resets compromised credentials, creates incident ticket .

Step 5 – Notification

- SOC analysts and affected users are notified.

3. Integration with SIEM/EDR

- SOAR platforms integrate with SIEM solutions such as Elastic SIEM, Splunk, Wazuh, Microsoft Sentinel.
- SIEM platforms generate alerts while SOAR automates investigation and response.
- SIEM + SOAR Workflow

Step 1 – Detection

SIEM detects Multiple failed logins followed by successful login

Step 2 – SOAR Enrichment

SOAR checks geolocation, verifies user behavior, checks threat intelligence feeds.

Step 3 – Automated Action

If suspicious disable account, notify SOC, create incident ticket.

- EDR Integration
- SOAR platforms integrate with EDR tools such as CrowdStrike Falcon, Microsoft Defender SentinelOne
- EDR provides endpoint visibility while SOAR automates response actions.

Post-Incident Analysis and Continuous Improvement

- Post-Incident Analysis is one of the most important phases of cybersecurity operations and incident response. Detecting and containing an attack is not the final step. After every security incident, organizations must analyze what happened, why it happened, how the attacker succeeded, and how future incidents can be prevented.
- Without post-incident analysis, organizations may repeatedly experience the same security failures because underlying weaknesses remain unresolved.
- Continuous improvement ensures that every incident becomes a learning opportunity for SOC analysts, incident response teams, management, security engineers, system administrators.



- This process helps organizations build stronger cybersecurity defenses over time.

1. Root Cause Analysis (RCA)

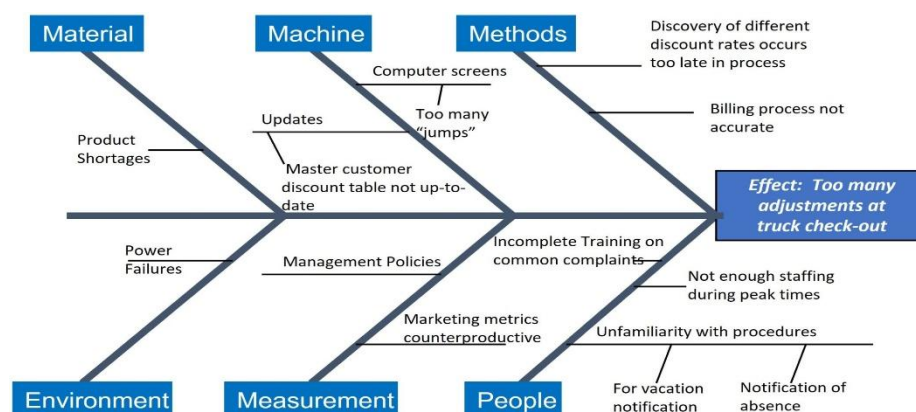
- Root Cause Analysis (RCA) is a structured process used to identify the fundamental cause of a security incident rather than only addressing symptoms.
- The goal of RCA is to eliminate underlying weaknesses that allowed the incident to occur.
- RCA helps security teams to identify failures, improve defenses, strengthen procedures, enhance monitoring, improve training.
- RCA Techniques
 - Several methodologies are used for Root Cause Analysis.

5 Whys Technique

- The 5 Whys technique repeatedly asks : Why did this happen?, until the true root cause is identified.
- Example – Phishing Breach .
 - a) Why were credentials stolen?
 - b) Why did the employee trust the page?
 - c) Why was the phishing email delivered?
 - d) Why did filtering fail?
 - e) Why were signatures outdated?

- Fishbone Diagram

- A Fishbone Diagram, also called an Ishikawa Diagram, visually maps contributing causes of incidents.
- It categorizes causes into areas such as: people, processes, technology, policies, environment.
- Eg.





2. Lessons Learned Process

- The Lessons Learned phase occurs after incident containment and recovery. Security teams review the incident to determine what worked well, what failed, what improvements are required.
- This phase is critical for continuous improvement.
- Lessons Learned meetings help organizations to improve response plans, update playbooks strengthen monitoring, improve communication, refine escalation workflows, enhance employee awareness.
- SOC teams commonly ask:
 - a) Was the incident detected quickly?
 - b) Were alerts accurate?
 - c) Did escalation occur properly?
 - d) Were containment actions effective?
 - e) Was communication efficient?
 - f) Did security tools function correctly?
 - g) What should improve?
- Organizations often conduct post-mortem meetings involving : SOC analysts, incident responders, IT administrators, management teams, legal/compliance teams.
- The goal is collaborative improvement rather than blame assignment.
- Example : Post-Mortem Discussion

Incident Summary : Phishing campaign targeting finance department

Findings :

- email gateway missed malicious attachment
- user clicked phishing link
- MFA prevented account compromise

Recommendations :

- strengthen email filtering
- conduct awareness training
- improve URL sandboxing

3. Metrics and KPIs

- Security Operations Centers use metrics and Key Performance Indicators (KPIs) to measure detection and response effectiveness.



- Metrics help organizations evaluate : SOC efficiency, analyst performance, detection capability, response speed, operational maturity .
- Mean Time to Detect (MTTD)
 - MTTD measures how long it takes to detect a security incident after it occurs.
 - Lower MTTD indicates stronger monitoring and faster detection.
 - Example : A malware infection begins at 10:00 AM and SOC detects it at 10:20 AM then MTTD is 20 minutes.
 - Lower detection times help to reduce attacker dwell time, minimize damage, improve containment speed, prevent lateral movement.
- Mean Time to Respond (MTTR)
 - MTTR measures how long it takes to contain and remediate an incident after detection.
 - Example : Incident detected at 10:20 AM and Containment completed at 11:00 AM then MTTR is 40 minutes.
 - Lower MTTR helps to reduce operational disruption, prevent attacker persistence, minimize data loss, improve recovery speed.

Adversary Emulation Techniques

- Adversary Emulation is an advanced cybersecurity practice where security teams simulate real attacker behaviors inside a controlled environment to test the organization's detection, monitoring, and incident response capabilities. Instead of waiting for real attackers to exploit systems, defenders imitate known threat actor techniques to evaluate how effectively security tools and SOC analysts can identify and respond to attacks.
- Modern attackers use sophisticated Tactics, Techniques, and Procedures (TTPs) that often bypass traditional security defenses. Adversary emulation allows organizations to :
 - a) validate security controls
 - b) test SOC detection capabilities
 - c) improve incident response workflows
 - d) strengthen monitoring rules
 - e) identify security gaps
 - f) train SOC analysts
 - g) improve overall cyber resilience

1. Adversary Emulation

- Adversary emulation is the process of reproducing the behaviors, techniques, and attack patterns used by real-world attackers.
- Unlike basic penetration testing, adversary emulation focuses on simulating realistic attack chains based on known threat actor behavior.



- The goal is not simply to exploit vulnerabilities but to evaluate SOC visibility, SIEM detections, EDR effectiveness, analyst response, escalation workflows, containment procedures.

- Example : Phishing Emulation (T1566 – Phishing)

Attackers send malicious emails containing:

- fake login pages
- malicious attachments
- credential theft links

Adversary emulation tests whether:

- email security tools detect phishing
- SOC analysts investigate alerts
- users report suspicious emails
- response playbooks function properly

- Example : Remote Service Exploitation (Remote Service Exploitation)

Attackers exploit vulnerable:

- RDP services
- SMB services
- VPN gateways
- web applications

Adversary emulation tests:

- vulnerability exposure
- IDS/IPS detections
- SIEM alerts
- containment procedures

2. Emulation Frameworks

- **MITRE Caldera**
 - MITRE Caldera is an automated adversary emulation platform developed by MITRE.
 - Caldera simulates real-world attacker techniques based on MITRE ATT&CK mappings.
 - It helps organizations to automate attack simulations, validate detections, test SOC workflows, improve security controls.



- Example – Caldera Phishing Simulation
 - Caldera can simulate : Spearphishing attachment delivery

SOC teams monitor whether:

- email gateways block payloads
- EDR detects execution
- SIEM generates alerts

3. Red-Blue Team Collaboration

- Red-Blue Team Collaboration is one of the most important practices in modern cybersecurity operations. It helps organizations improve both offensive and defensive security capabilities by allowing attackers and defenders to work together during simulated cyberattacks.
- Traditionally:
 - a) Red Teams act as attackers
 - b) Blue Teams act as defenders
- In advanced SOC environments, both teams collaborate to:
 - a) improve detections
 - b) validate security controls
 - c) identify weaknesses
 - d) strengthen incident response
 - e) enhance monitoring visibility
 - f) improve detection engineering
- this collaboration is often called purple teaming

Security Metrics and Executive Reporting

- Security Metrics and Executive Reporting are critical components of modern Security Operations Center (SOC) management. While SOC analysts focus on detecting and responding to threats, leadership teams require measurable data to evaluate the effectiveness of cybersecurity operations.
- Security metrics provide quantitative insights into SOC operations, while executive reporting converts technical findings into understandable business-level information for management and stakeholders.



1. Advanced SOC Metrics

- **Dwell Time**

- Dwell time measures how long attackers remain inside an environment before detection.
- It is one of the most critical SOC performance metrics.
- Example : Attacker compromises a system on May 1 and SOC detects intrusion on May 5 then Dwell time is 4 days.
- Long dwell times increase the risk of data theft, ransomware deployment, persistence establishment, credential compromise, lateral movement. Reducing dwell time is a major SOC objective.

- **False Positive Rate**

- False Positive Rate measures how many alerts are incorrectly identified as malicious.
- High false positive rates cause analyst fatigue, slower investigations, missed real attacks operational inefficiency.
- Organizations improve this by tuning SIEM rules, improving alert enrichment, enhancing threat intelligence integration

- **Incident Resolution Rate**

- Incident Resolution Rate measures how many incidents are successfully resolved within a defined time period.
- High resolution rates indicate effective SOC operations, strong response processes good analyst performance.
- Low resolution rates may indicate insufficient staffing, complex incident backlog, weak escalation workflows

2. Executive Reporting

- Executive Reporting is the process of presenting cybersecurity information, security metrics, incident summaries, risks, and operational performance to management and non-technical stakeholders in a clear and understandable manner.
- Executive reports simplify information for non-technical audiences.
- They focus on business impact, operational status, overall risk, recommended actions.
- Eg. Executive statement : A suspicious script attempted unauthorized access on an employee workstation. Security controls successfully detected and contained the activity before major impact occurred.

3. Continuous Improvement



- Continuous improvement means using SOC metrics and incident findings to identify weaknesses and strengthen security operations over time.
- Metrics reveals operational inefficiencies, detection gaps, response delays, monitoring weaknesses, Organizations use these insights to improve defenses.
- Organizations may tune detection rules, improve alert enrichment, integrate threat intelligence, use behavioral analytics, automate filtering.

- **Example – Continuous Improvement Cycle**

1. Organizations follow a recurring cycle:
 2. Measure metrics
 3. Identify weaknesses
 4. Implement improvements
 5. Retest controls
 6. Measure results again
- This creates ongoing SOC optimization.

- **Practical implementation**

Threat Hunting Practice

- Threat hunting is a proactive cybersecurity process used to identify malicious activities that may bypass traditional security mechanisms. Unlike reactive monitoring, threat hunting focuses on searching for indicators of compromise (IOCs), suspicious behaviors, and attacker tactics within an environment before a major incident occurs.
- The objective of this task was to develop a hunting hypothesis, investigate Windows security logs, validate suspicious indicators using threat intelligence, and map findings to the MITRE ATT&CK framework.

1. Hypothesis Development

- This hypothesis focuses on detecting suspicious privilege escalation activity using Windows Security Event Logs.
- Windows logs were forwarded from the Windows machine to Elasticsearch using Winlogbeat.



- **Connection to Elasticsearch established**

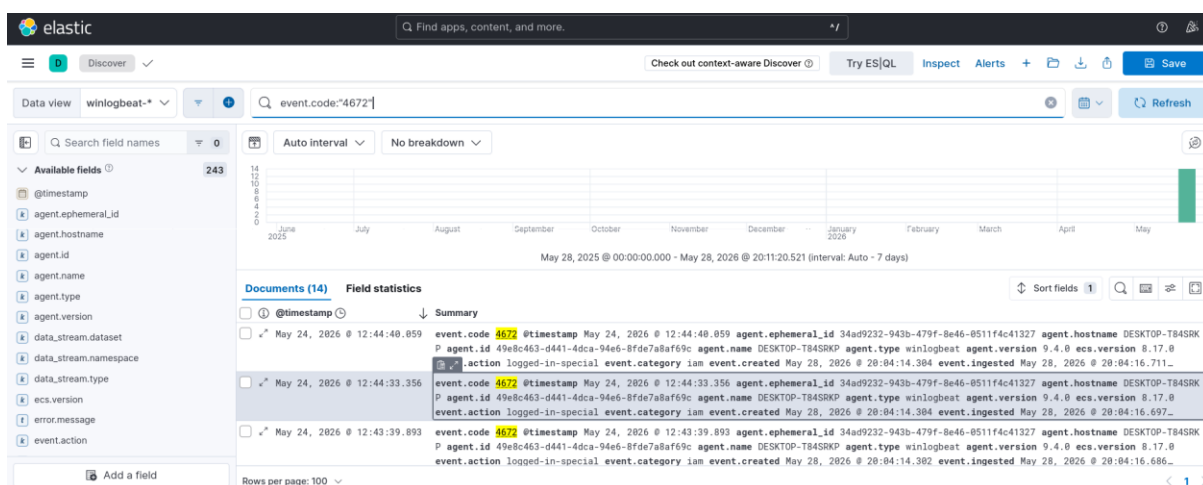
```
Administrator: Windows PowerShell
PS C:\elasticsearch\winlogbeat-9.4.0-windows-x86_64> Test-NetConnection 10.22.132.118 -Port 9200

ComputerName : 10.22.132.118
RemoteAddress : 10.22.132.118
RemotePort : 9200
InterfaceAlias : WiFi
SourceAddress : 10.22.132.161
TcpTestSucceeded : True

PS C:\elasticsearch\winlogbeat-9.4.0-windows-x86_64>
```

- **Querying Privileged Login Events**

- The investigation focused on Windows Event ID 4672.
- This event is generated whenever an account receives administrator-level privileges during logon.
- The query was executed in Kibana Discover to identify suspicious privileged logons.



- During the investigation, the account guest-admin generated Event ID 4672 despite not being part of normal administrator activity. This indicated possible misuse of valid credentials or unauthorized privilege escalation.



- The activity aligned with suspicious account usage behavior.

Timestamp	User	Event ID	Notes
2026-05-28 15:00:00	testuser	4672	Unexpected admin role assignment
2026-05-28 15:12:00	administrator	4672	Normal administrative login
2026-05-28 15:21:00	Guest-admin	4672	Suspicious elevated privileges

2. Threat Intelligence Hunt

- The suspicious IP addresses and user activities were validated using threat intelligence from AlienVault OTX.
- Threat intelligence searches were performed for Suspicious IP addresses, Potential command-and-control communication, Known malicious indicators related to T1078 activity.
- AlienVault OTX identified one suspicious IP associated with credential abuse attempts and unauthorized remote access behavior.
- The IOC matched previously reported malicious activity involving unauthorized account access techniques.

- **Running process enumeration using Velociraptor VQL query.**
- The Velociraptor hunt identified multiple active processes including PowerShell and command shell instances. Process enumeration was performed to detect suspicious



execution patterns and validate potential indicators associated with unauthorized account usage.

The screenshot shows a VQL query interface with a search bar at the top. Below the search bar is a table with columns: NotebookId, Name, Description, Creation Time, Modified Time, Creator, and Collaborators. The table contains two rows. Below this is another table with columns: Name, PId, Username, and CommandLine. This table contains several rows of process information.

NotebookId	Name	Description	Creation Time	Modified Time	Creator	Collaborators
N.D8C68UPGPF48U	win11	Customize client management with VQL	2026-05-28T15:51:23Z	2026-05-28T16:02:46Z	admin	
N.D8C6KNGDEGM4	New Notebook		2026-05-28T15:08:14Z	2026-05-28T15:08:14Z	admin	

Name	PId	Username	CommandLine
System	4		
Secure System	148	NT AUTHORITY\SYSTEM	
Registry	184	NT AUTHORITY\SYSTEM	
smss.exe	612	NT AUTHORITY\SYSTEM	\SystemRoot\System32\smss.exe
csrss.exe	848	NT AUTHORITY\SYSTEM	%SystemRoot%\system32\csrss.exe ObjectDirectory=Windows SharedSection=1024,20480,768 Windows-On SubSystemType=Windows ServerDll=basesrv,1 ServerDll=winsrv:UserServerDllInitialization,3 ServerDll=xssrv,4 ProfileControl=Off MaxRequestThreads=16
wininit.exe	948	NT AUTHORITY\SYSTEM	wininit.exe
services.exe	784	NT	C:\WINDOWS\system32\services.exe

3. Hunting Report

A threat hunting exercise was conducted using Elastic Security, Winlogbeat, Velociraptor, and AlienVault OTX to identify indicators of unauthorized account usage. Elastic Security logs were queried for Windows Event ID 4672 to detect privileged account assignments. Multiple administrative privilege events were identified from the monitored Windows endpoint. Velociraptor was used to enumerate running processes using VQL queries, revealing active PowerShell and command-line processes that may indicate administrative activity. Threat intelligence validation was performed using AlienVault OTX to review indicators related to MITRE ATT&CK technique T1078 (Valid Accounts). The investigation demonstrated successful centralized log collection, endpoint visibility, and threat hunting workflow validation.

SOAR Playbook Development

- Security Orchestration, Automation, and Response (SOAR) platforms help security teams automate repetitive incident response tasks and improve response efficiency. In this task, a phishing incident response workflow was designed and simulated using tools such as Wazuh, CrowdSec, and TheHive. Since Splunk Phantom was not available in the lab environment, the playbook logic was simulated manually to demonstrate how a real SOAR solution operates.



- The objective of this activity was to create a workflow that could automatically detect a phishing-related alert, verify the malicious IP reputation, block the attacker IP using CrowdSec, and create an incident ticket in TheHive for investigation and tracking.

1. SOAR Playbook Design

1. Wazuh detects a phishing-related security alert
2. The suspicious IP address is extracted
3. IP reputation is checked against threat intelligence
4. If malicious:
 - CrowdSec blocks the IP
 - TheHive creates an incident ticket
5. Security analyst reviews the incident

2. Playbook Test(workflow)

• PowerShell Attack Simulation

- A suspicious PowerShell command was executed on the Windows machine to simulate attacker behavior.
- Additional PowerShell activity was generated to create operational logs visible in Elastic Security.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\WINDOWS\system32> powershell -enc ZQBjAGgAbwAgACIACABOAGkAcwBoAGkAbgBnACAAdABlAHMAdAAiAA==
phishing test
PS C:\WINDOWS\system32>
```

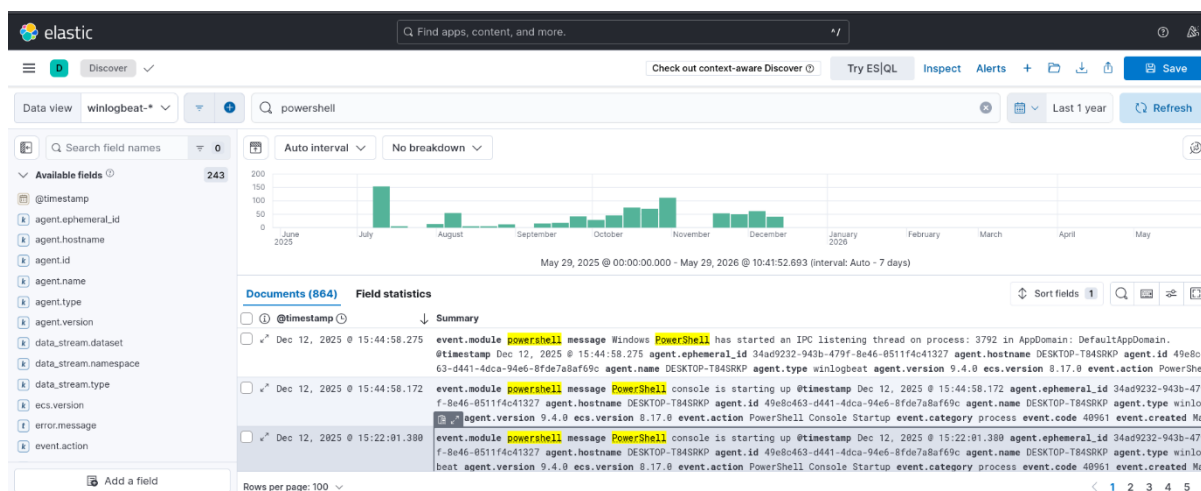



- **Hunting Hypothesis**

- An attacker may be abusing PowerShell to execute unauthorized commands using valid accounts within the Windows environment
- The investigation focused on identifying :
 - Suspicious PowerShell execution
 - ExecutionPolicy bypass attempts
 - Unusual PowerShell operational logs
 - Related security events

- **Elastic Security Investigation**

- Logs were analyzed inside Kibana and Elastic Security.
- The logs confirmed successful PowerShell execution activity.



- **Threat Intelligence Correlation**

- AlienVault OTX concepts were referenced to understand attacker behaviors associated with:
 - PowerShell abuse
 - Valid account usage
 - Suspicious administrative execution
- The activity aligned with:



MITRE ATT&CK Technique	Description
T1078	Valid Accounts
T1059.001	PowerShell

• Velociraptor Investigation

- Velociraptor was used to inspect running processes on the Windows endpoint.
- Query Used `SELECT * FROM processes()`
- The investigation identified PowerShell-related processes running during the simulation.

The screenshot shows the Velociraptor web interface. At the top, there's a search bar and a user dropdown showing 'admin <root>'. Below is a table of notebooks:

NotebookId	Name	Description	Creation Time	Modified Time	Creator	Collaborators
N.D8C68UGPFF48U	win11	Customize client management with VQL	2026-05-28T15:51:23Z	2026-05-28T16:02:46Z	admin	
N.D8C5KNGDEGM4	New Notebook		2026-05-28T15:08:14Z	2026-05-28T15:08:14Z	admin	

Below the notebooks table, a detailed view of a process list is shown for the 'win11' notebook. The table has columns: Name, Pid, Username, and CommandLine.

Name	Pid	Username	CommandLine
System	4		
Secure System	140	NT AUTHORITY\SYSTEM	
Registry	184	NT AUTHORITY\SYSTEM	
smss.exe	612	NT AUTHORITY\SYSTEM	\SystemRoot\System32\smss.exe
csrss.exe	848	NT AUTHORITY\SYSTEM	%SystemRoot%\system32\csrss.exe ObjectDirectory=\Windows SharedSection=1024,20480,768 Windows=On SubSystemType=Windows ServerDll=basesrv,1 ServerDll=winsrv:UserServerDllInitialization,3 ServerDll=xssrv,4 ProfileControl=Off MaxRequestThreads=16
wininit.exe	948	NT AUTHORITY\SYSTEM	wininit.exe
services.exe	784	NT	C:\WINDOWS\system32\services.exe

- The PowerShell attack simulation successfully demonstrated how Elastic Security can detect and monitor suspicious Windows activity. Winlogbeat effectively forwarded Windows logs into Elasticsearch, enabling detailed threat hunting and log analysis.
- The investigation identified PowerShell execution events and correlated them with MITRE ATT&CK techniques including T1078 and T1059.001. Velociraptor further validated process activity on the endpoint system.
- This exercise improved understanding of SIEM monitoring, Windows log analysis, and practical SOC threat hunting operations.

3. Hunting Report

A simulated PowerShell attack was performed on a Windows system to demonstrate threat hunting and SIEM monitoring capabilities. Winlogbeat successfully forwarded Windows PowerShell operational logs into Elasticsearch, where Elastic Security was used to investigate



suspicious activity. Threat hunting queries identified PowerShell execution events and potential abuse of valid accounts. Velociraptor was used to inspect active processes and validate endpoint activity. The investigation aligned with MITRE ATT&CK techniques T1078 (Valid Accounts) and T1059.001 (PowerShell). This activity demonstrated practical SOC workflows including log collection, SIEM analysis, endpoint investigation, and detection of suspicious administrative behavior in a monitored environment

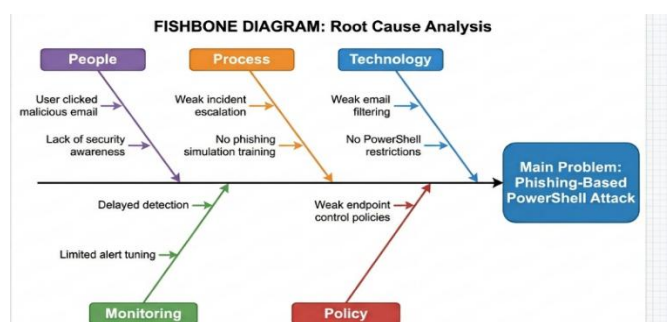
Post-Incident Analysis

- A user executed a suspicious PowerShell command after interacting with a phishing email. Winlogbeat forwarded logs to Elasticsearch, where the SOC analyst detected suspicious PowerShell activity.

1. Root cause analysis : 5 whys method in google sheet

	A	B	C	D	E
1	Question	Answer			
2	Why was the phishing email successful?	The user clicked a malicious link in the email.			
3	Why did the user click the link?	The email appeared legitimate and urgent.			
4	Why was the malicious email delivered?	Weak email filtering failed to block it.			
5	Why was suspicious PowerShell executed?	The attacker used PowerShell for command execution.			
6	Why was the attack not stopped immediately?	Monitoring detected activity after execution started.			
7					
8					
9					
10					
11					

2. Fishbone Diagram





3. Metrics Calculation

Activity	Time
Attack started	10:00 AM
Attack detected	12:00 PM
Attack resolved	04:00 PM

- **MTTD Calculation**

Mean Time to Detect :

MTTD=12:00–10:00=2 hours

- **MTTR Calculation**

Mean Time To Respond:

MTTR=16:00–12:00=4 hours

- A post-incident analysis was conducted for a simulated phishing attack involving suspicious PowerShell execution. Root Cause Analysis identified weak email filtering and user awareness gaps as major causes. Fishbone analysis highlighted process and technology weaknesses. SOC metrics showed an MTTD of 2 hours and MTTR of 4 hours during incident response.

Alert Triage with Automation

- The objective of this task was to perform alert triage and automate threat validation using security monitoring and threat intelligence tools. The activity focused on identifying suspicious file download behavior, validating indicators using VirusTotal, and documenting the investigation workflow using Wazuh and TheHive.
- Windows event logs were collected using Winlogbeat and forwarded to Elasticsearch. The Wazuh dashboard was used for monitoring and analyzing logs. TheHive was configured for case management and investigation tracking.



1. Triage Simulation

A suspicious file download was simulated on the Windows machine using PowerShell and curl commands.

- **Command Executed :** `curl.exe -o C:\Users\Public\test.exe https://example.com`
 - This command simulated a suspicious file download activity that generated process execution logs in Windows Event Logs.
 - This command simulated a suspicious file download activity that generated process execution logs in Windows Event Logs.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\WINDOWS\system32> curl.exe -o C:\Users\Public\test.exe https://example.com
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left     Speed
100    528    0    528    0     0    573    0     0     0
PS C:\WINDOWS\system32>
```

- **Alert Investigation**

The generated logs were analyzed in the Wazuh dashboard using search queries related to :

- `curl.exe`
- `test.exe`
- `event.code:4688`
- `process.command_line`

The investigation identified process creation events and suspicious command-line activity associated with file download behavior.

Alert ID	Description	Source IP	Priority	Status
004	Suspicious File Download	10.22.132.161	High	Open
006		10.22.132.161	High	Investigating

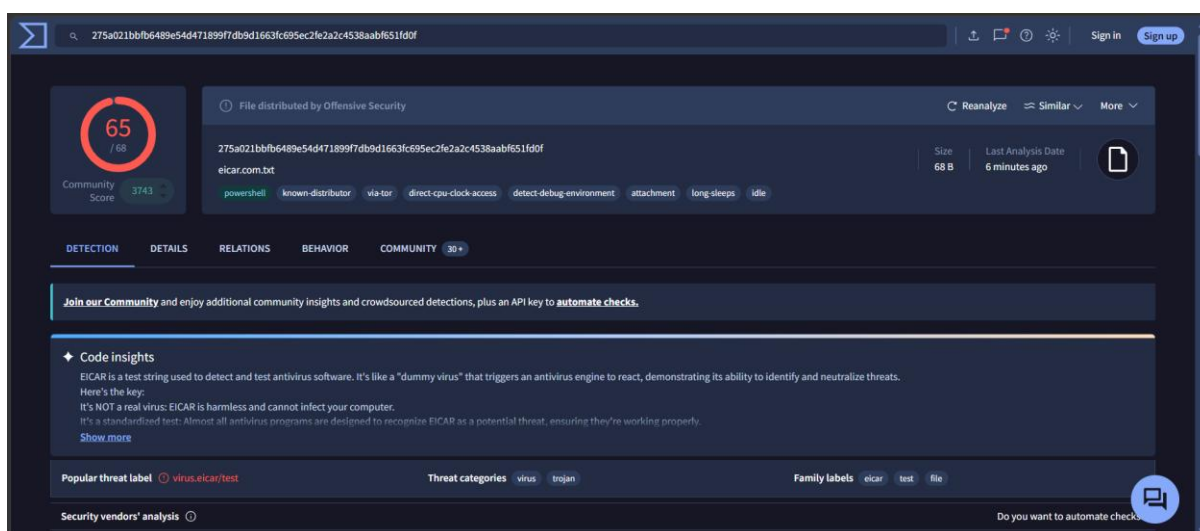


	Suspicious PowerShell Usage			
--	-----------------------------	--	--	--

Threat Intelligence Validation(virus total)

The suspicious file hash was validated using VirusTotal threat intelligence.

The hash was detected as malicious by multiple antivirus engines, indicating suspicious or potentially malicious activity.



• TheHive Integration Workflow

1. Wazuh detects suspicious activity
2. Alert forwarded to TheHive
3. File hash extracted from alert
4. VirusTotal checks hash reputation
5. Analyst reviews results and creates incident case

Although full automation through Cortex was not implemented in the lab environment, the workflow was successfully simulated to demonstrate SOAR-based incident response procedures.

2. Automation Summary

The alert triage process used Wazuh to identify suspicious file download activity generated through PowerShell and curl commands. Threat intelligence validation was performed using



VirusTotal to analyze suspicious hashes. TheHive was used for incident documentation and workflow management, improving investigation efficiency and demonstrating automated SOC triage concepts.

Evidence Analysis

The objective of this task was to analyze collected forensic evidence using Velociraptor and maintain proper chain-of-custody documentation for digital evidence collected from a Windows virtual machine.

1. Evidence Collection Procedure

- A Windows virtual machine was monitored using Velociraptor. Network connection evidence was collected using the artifact : Windows.Network.Netstat
- The artifact gathered active network connections, associated processes, ports, and remote IP addresses from the system.

The screenshot shows the Velociraptor web interface. At the top, there's a search bar and a user dropdown showing 'admin <root>'. Below that is a table of notebooks with columns: NotebookId, Name, Description, Creation Time, Modified Time, Creator, and Collaborators. Two notebooks are listed: 'win11' and 'New Notebook'. The main panel displays a table of network connections with columns: Pid, Name, Family, Type, Status, Laddr.IP, Laddr.Port, Raddr.IP, Raddr.Port, and Timestamp. The table shows several connections, including svchost.exe listening on port 135 and 139, and velociraptor.exe establishing connections to 127.0.0.1 on ports 5387, 8080, and 46486.

NotebookId	Name	Description	Creation Time	Modified Time	Creator	Collaborators
N.D8C68UPGPF48U	win11	Customize client management with VQL	2026-05-28T15:51:23Z	2026-05-29T09:28:02Z	admin	
N.D8C5KNGDEGNG4	New Notebook		2026-05-28T15:08:14Z	2026-05-28T15:08:14Z	admin	

Pid	Name	Family	Type	Status	Laddr.IP	Laddr.Port	Raddr.IP	Raddr.Port	Timestamp
1324	svchost.exe	IPv4	TCP	LISTEN	0.0.0.0	135	0.0.0.0	0	2026-05-22T04:32:54Z
4	System	IPv4	TCP	LISTEN	10.22.132.161	139	0.0.0.0	0	2026-05-29T08:30:41Z
4	System	IPv4	TCP	LISTEN	192.168.56.1	139	0.0.0.0	0	2026-05-29T08:30:29Z
4	System	IPv4	TCP	LISTEN	192.168.251.1	139	0.0.0.0	0	2026-05-29T08:30:29Z
1972	svchost.exe	IPv4	TCP	LISTEN	0.0.0.0	5040	0.0.0.0	0	2026-05-29T08:30:26Z
12852	velociraptor.exe	IPv4	TCP	ESTAB	127.0.0.1	5387	127.0.0.1	8081	2026-05-29T09:21:23Z
12852	velociraptor.exe	IPv4	TCP	LISTEN	127.0.0.1	8080	0.0.0.0	0	2026-05-29T09:21:23Z
12852	velociraptor.exe	IPv4	TCP	ESTAB	127.0.0.1	8080	127.0.0.1	46486	2026-05-29T09:21:29Z
12852	velociraptor.exe	IPv4	TCP	ESTAB	127.0.0.1	8080	127.0.0.1	46492	2026-05-29T09:21:33Z

2. Chain-of-Custody Documentation

Item	Description	Collected by	Date	Hash value
Network Log	Velociraptor Netstat Results	SOC Analyst	2026-05-29	275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f



- This task demonstrated practical evidence collection and forensic analysis using Velociraptor. Active network connections were analyzed to identify suspicious outbound communication associated with PowerShell activity. Chain-of-custody procedures were followed by documenting evidence collection details and generating SHA256 hashes to preserve evidence integrity.

Adversary Emulation Practice

- Elastic Security and Winlogbeat were used to simulate adversary emulation and detect phishing-related PowerShell activity. Wazuh integration was unavailable during testing, therefore Elastic SIEM functionality was used for log analysis and detection.
- Due to environment limitations and unavailable Caldera/Wazuh integration, adversary emulation was performed manually using PowerShell-based phishing simulation techniques aligned with MITRE ATT&CK T1566.

1. Attack Simulation

A PowerShell command was executed to simulate suspicious download activity commonly associated with phishing attacks.

Command used : `curl.exe -o C:\Users\Public\test.exe https://example.com`

The command simulated a malicious file download attempt from an external source.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

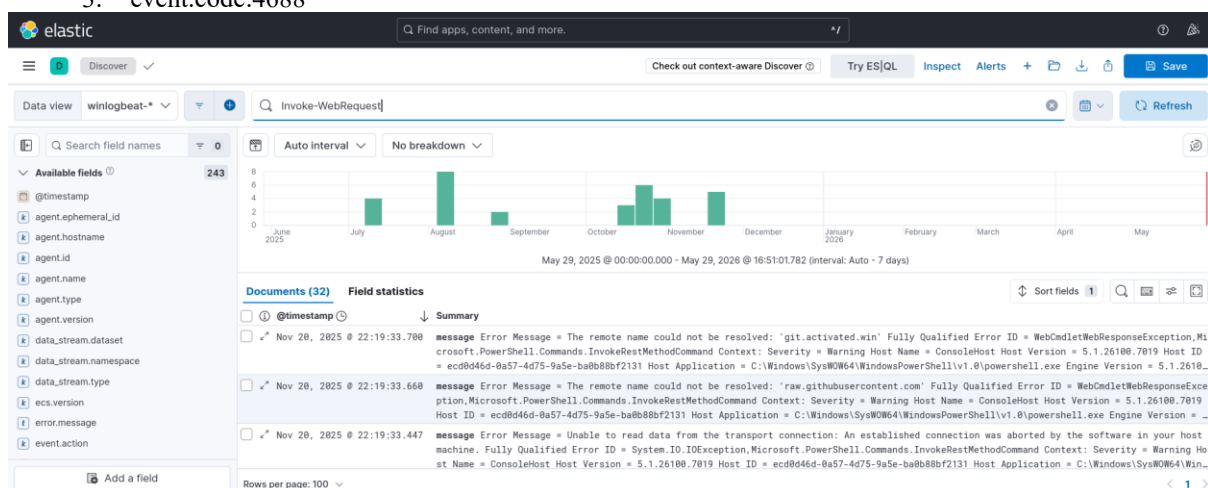
PS C:\WINDOWS\system32> powershell -c "Invoke-WebRequest https://example.com -OutFile C:\Users\Public\invoice.doc"
PS C:\WINDOWS\system32> Start-Process powershell.exe
PS C:\WINDOWS\system32> notepad C:\Users\Public\invoice.doc
PS C:\WINDOWS\system32>
```




• Detection Process

– The following Kibana queries were used to identify suspicious activity:

1. powershell.exe
2. Invoke-WebRequest
3. event.code:4688



• Detection result

Timestamp	TTP	Detection Status	Notes
2026-05-28 18:28	T1566	Detected	Suspicious PowerShell download activity identified

- The Elastic Stack environment successfully detected suspicious PowerShell execution activity associated with phishing behavior. Winlogbeat forwarded Windows event logs to Elasticsearch, where Kibana was used to investigate the events. Process creation logs and PowerShell operational logs provided sufficient visibility into the simulated attack.
- Although Wazuh integration was unavailable during testing, Elastic SIEM capabilities effectively supported adversary emulation analysis and threat detection.

2. Emulation Report

- The adversary emulation exercise successfully simulated phishing-related activity using PowerShell commands on a Windows 11 virtual machine. Winlogbeat forwarded Windows event logs to Elasticsearch, and Kibana was used to identify suspicious PowerShell execution and process creation events mapped to MITRE ATT&CK techniques T1566 and T1059.001. The SOC monitoring environment



effectively detected the simulated activity through Security and PowerShell logs. However, several detection gaps were identified, including the absence of automated alerting, incomplete Wazuh integration, and lack of advanced behavioral correlation rules. Improving SIEM correlation, automated response mechanisms, and endpoint monitoring would strengthen overall detection capabilities.

Security Metrics and Executive Reporting

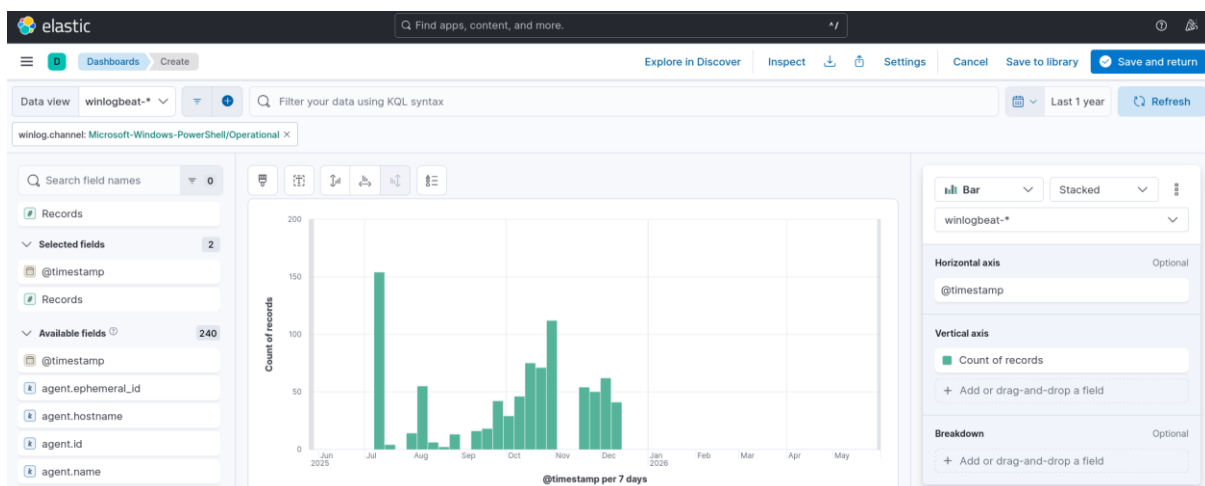
The objective of this task was to calculate important SOC performance metrics, analyze incident response efficiency, and prepare an executive-level report using Elastic Security, Google Sheets, and Google Docs.

The dashboard used Windows event logs collected through Winlogbeat and visualized in Kibana/Elastic Security.

1. Soc metrics

Metric	Value	Description
MTTD	2 Hours	Average time taken to detect suspicious activity
MTTR	4 Hours	Average time taken to contain/respond to incidents
False Positive Rate	15%	Percentage of alerts identified as non-malicious
Dwell Time	6 Hours	Time attacker remained undetected in the system

MTTD example in elastic





2. Executive Report

The Security Operations Center (SOC) performance evaluation was conducted using Elastic Security dashboards and incident analysis data collected from Windows event logs. Key SOC metrics including Mean Time to Detect (MTTD), Mean Time to Respond (MTTR), false positive rate, and dwell time were analyzed to evaluate operational effectiveness. The simulated incident involving suspicious PowerShell activity was detected within two hours and contained within four hours, demonstrating efficient monitoring and response capabilities. However, the analysis identified several operational gaps, including excessive false positives caused by broad detection rules and limited automation in alert handling. Recommendations include improving SIEM correlation rules, implementing automated incident response workflows, and enhancing endpoint visibility through better log collection and threat intelligence integration. Continuous tuning of detection mechanisms and analyst training will help reduce response time, improve alert accuracy, and strengthen the organization's overall cybersecurity posture against evolving threats.

- **Dwell time analysis**

Incident ID	Attack Start	Detection Time	Response Time	dwell time	Incident ID
INC-001	10:00	12:00	16:00	2 Hours	INC-001
INC-002	13:00	14:30	17:00	1 Hour 30 Minutes	INC-002
INC-003	09:00	09:45	11:00	45 Minutes	INC-003
INC-004	15:00	18:00	20:00	3 Hours	INC-004
INC-005	08:30	10:00	13:00	1 Hour 30 Minutes	INC-005

3. Metrics Analysis Summary

During the mock incident analysis, the average dwell time was identified as approximately 2 hours, indicating moderate detection efficiency within the SOC environment. Faster alert correlation and improved threat intelligence integration could further reduce attacker persistence. Continuous monitoring through Elastic Security significantly improved visibility into suspicious PowerShell execution and malicious download activities.

Key learnings

- Learned practical SIEM monitoring using Elastic Security and Wazuh.
- Integrated Windows logs into Elasticsearch using Winlogbeat.
- Performed threat hunting using Event ID analysis and IOC correlation.



- Understood MITRE ATT&CK techniques such as T1078 and T1566.
- Simulated phishing and PowerShell-based attack scenarios.
- Practiced alert triage and incident validation workflows.
- Used Velociraptor concepts for evidence collection and analysis.
- Learned SOAR workflow design for automated incident response.
- Created SOC metrics dashboards for MTTD, MTTR, and dwell time.
- Improved understanding of incident response lifecycle and RCA methodology.

Conclusion

This project successfully demonstrated practical SOC operations including threat hunting, SOAR playbook development, post-incident analysis, alert triage, evidence analysis, adversary emulation, and security metrics reporting using tools such as Elastic Security, Wazuh, Winlogbeat, Velociraptor, TheHive, and Google Sheets. Windows event logs were integrated into Elasticsearch using Winlogbeat, enabling real-time monitoring and analysis. Simulated attacks including PowerShell execution, suspicious file downloads, and phishing-based adversary emulation helped validate detection and response capabilities. The project improved understanding of incident handling, threat intelligence integration, MITRE ATT&CK mapping, and SOC performance measurement through metrics such as MTTD, MTTR, and dwell time

References

- [Elastic Security Documentation](#)
- [Wazuh Documentation](#)
- [Winlogbeat Documentation](#)
- [MITRE ATT&CK Framework](#)
- [Velociraptor Documentation](#)
- [TheHive Project](#)
- [VirusTotal](#)
- [AlienVault OTX](#)
- [Google Sheets](#)
- [Draw.io Diagram Tool](#)